

PhishGuard — Complete Hackathon Presentation Guide (SIH 2026)

1. One-Line Pitch

"PhishGuard catches the phishing emails that don't look like phishing emails — by combining instant local heuristics with LLM-grade semantic reasoning, and it never goes down."

2. The Story Arc (Use This Order On Slides)

1. **Hook** — a real BEC scam example with no malicious link/attachment, that still cost a company money.
2. **Problem** — why legacy tools miss it.
3. **Insight** — semantic understanding is the missing layer.
4. **Solution** — PhishGuard's hybrid architecture.
5. **Demo** — live message → verdict.
6. **Resilience** — what happens when the internet/API dies (this is your differentiator).
7. **Impact/Scale** — who this helps and at what cost.
8. **Roadmap** — what's next.

Judges remember *stories*, not architecture diagrams — lead with the scam example, not the tech stack.

3. Problem Statement (Expanded)

- Over 90% of breaches begin with email/social engineering rather than pure malware — attackers have moved from "**trick the antivirus**" to "**trick the human**."
- Modern BEC scams often contain:
 - No attachment
 - No malicious link
 - Just authority impersonation + urgency + a payment/gift-card/wire-transfer ask
- **Why old tools fail:** Secure Email Gateways (SEGs) are pattern-matchers — they check sender reputation, blacklists, known malware signatures. A grammatically perfect email from a spoofed "CEO" asking for gift cards has *zero* traditional red flags.
- **Why pure-cloud-AI tools also fail:** if the vendor's API rate-limits, has an outage, or your organization loses connectivity, the *entire* detection pipeline goes dark — right when attackers might be exploiting the same outage window.

The gap PhishGuard fills: a system that reasons about intent and social engineering *and* keeps working when the cloud doesn't.

4. Solution Overview

PhishGuard is a **multi-layered, fail-safe detection pipeline**:

Layer	Purpose	Speed
1. PII Anonymization	Redact sensitive data before anything leaves the device	instant
2. Heuristic Engine	Typosquatting, domain age, URL reputation	milliseconds–seconds
3. Cloud LLM Reasoning	Semantic/social-engineering understanding	<1–2s
4. Failover + Offline Fallback	Keeps working with zero internet	instant

Core philosophy: "Fail open, never fail dark." Every layer has a fallback so the system degrades gracefully instead of collapsing.

5. Deep-Dive Architecture (Presentation-Ready Explanations)

Layer 1 — PII Anonymization

- Regex-based local redaction of names, emails, phone numbers, account numbers **before** any payload is sent to a third-party LLM API.
- Why it matters: this is your answer to every privacy/compliance question a judge asks.

Layer 2 — Heuristics & Reputation

- **Typosquatting detection:** Levenshtein edit-distance between the sender/link domain and a curated list of commonly spoofed brands. Distance of 1–2 (e.g., `paypa1.com`) = high-confidence flag.
- **Domain age (RDAP):** queries a public RDAP registry to get a domain's registration date. Anything younger than ~30 days is treated as high-risk infrastructure — scammers rarely reuse old domains.
- **URL reputation (VirusTotal v3):** URLs are base64url-encoded and checked against VirusTotal's aggregated engine reports; unscanned URLs get submitted fresh. Thresholds: any "malicious" verdict, or 3+ "suspicious" verdicts, trigger a flag.

Layer 3 — Cloud LLM Reasoning

- Primary model: a low-latency LLM (sub-second) evaluated against a structured security rubric (authority impersonation, urgency cues, payment redirection, unusual requests).
- This is the layer that catches the "I'm in a meeting, buy gift cards" style scam that has **no technical indicators at all** — only human-language ones.

Layer 4 — Failover & Offline Resilience

- **LLM failover:** if the primary provider rate-limits or errors out, the system automatically retries against a secondary and tertiary provider.
- **Fully offline fallback:** if *no* LLM provider is reachable, a local rubric-based NLP parser scores the message using similarity matching against a small labeled reference set, plus local regex checks — so the system still produces a verdict with zero internet.
- **Storage failover:** if the primary database is unreachable, logs and results fall back to local file-based storage so nothing is lost.

Slide framing tip: draw this as a **decision waterfall**, not a flat diagram — Cloud LLM → Backup LLM → Offline Rubric → (always) Local Storage. That visual alone answers "what if X breaks?" before anyone asks.

6. Tech Stack Summary (fill in your actual stack here)

Component	Suggested framing
Backend	Async Python/Node service orchestrating the 4 layers
Primary LLM	Fast-inference provider chosen for <1s latency
Backup LLMs	Secondary cloud providers for redundancy
Reputation APIs	Public RDAP registry + VirusTotal v3
Database	Primary document store + local JSON fallback
Offline classifier	Lightweight similarity-based NLP scorer

7. Pitch Scripts

30-Second Elevator Pitch

"PhishGuard is an adaptive, multi-layered threat detector that combines fast local heuristics with deep LLM reasoning to catch social engineering attacks — the ones with no malicious link or attachment. Unlike traditional tools that go dark during a network drop or API outage, PhishGuard has automatic LLM failover and a fully offline rubric fallback, so protection never stops."

60-Second Version (add this)

"Most phishing today isn't a bad link — it's a fake urgent email from 'the CEO' asking someone to buy gift cards. Legacy filters miss this because there's nothing technical to flag. PhishGuard closes that gap: local heuristics catch typosquatted domains and suspicious infrastructure in milliseconds, while an LLM reasoning layer understands intent — urgency, authority impersonation, payment redirection. And because security tools can't afford downtime, PhishGuard has a full failover chain: if one LLM provider fails, it tries the next; if all cloud AI is unreachable, it falls back to an offline rubric classifier. It never goes dark."

2-Minute Demo Narration

1. Open with the scam email example.
2. Show heuristic layer flagging domain age / typosquat instantly.
3. Show LLM layer explaining *why* it's flagged (the social-engineering reasoning).
4. Kill the network / simulate an API failure live.
5. Show the offline fallback still producing a verdict.
6. Close on the dashboard/report view.

This live "kill the internet" demo moment is your single best differentiator on stage — plan the whole talk around building up to it.

8. Suggested Slide Deck Structure (10–12 slides)

1. Title + tagline
2. The scam example (screenshot/story)
3. Why current tools fail (SEGs vs. pure-cloud-AI)
4. Our insight: hybrid, fail-safe design
5. Architecture diagram (4-layer waterfall)
6. Heuristics deep dive (typosquat / RDAP / VirusTotal)
7. LLM reasoning layer + example verdict
8. Resilience: failover + offline fallback (your differentiator slide)
9. Live demo
10. Impact & who benefits (SMEs, enterprises, government)
11. Roadmap / future scope
12. Ask / close

9. Expected Q&A — Full Set

Q: Why not just use regex/keyword filters? A: Regex catches known words, not intent. "I'm in a meeting, don't call, please purchase gift cards" has zero flaggable keywords or links, yet is a textbook BEC scam. Only semantic reasoning catches that.

Q: How do you protect user privacy when sending data to cloud LLMs? A: A local PII-anonymization layer strips names, emails, phone numbers, and account numbers *before* anything leaves the device — the cloud model never sees raw personal data.

Q: What happens if you lose internet access entirely? A: The system fails open, not closed. It runs local heuristics (typosquat detection, link mismatch checks) and an offline rubric-based classifier to still produce a verdict, then logs results locally.

Q: What if your LLM provider is down or rate-limited? A: Automatic failover to a secondary, then tertiary LLM provider before ever falling back to the fully offline classifier.

Q: How do you avoid false positives, e.g., legitimate urgent emails from an actual CEO? A: (Answer honestly based on your actual testing — e.g., "the rubric weighs multiple signals together — urgency alone doesn't trigger a flag; it needs to combine with an unusual request type, a mismatched domain, or a newly registered sending infrastructure.") Be ready to give a real false-positive rate if you've measured one.

Q: How does this scale to enterprise email volume? A: The heuristic layer runs in milliseconds and filters most traffic; only ambiguous cases escalate to the (slower, costlier) LLM layer, keeping average cost and latency low.

Q: What's your accuracy / have you benchmarked it? A: Be ready with real numbers from your test set — judges will ask this directly. If you don't have a large labeled dataset, be upfront: "tested against a curated regression set of N labeled phishing/legitimate samples; here's precision/recall."

Q: Isn't relying on a third-party LLM a single point of failure? A: That's exactly why we built the multi-provider failover plus a fully offline fallback — no single vendor outage can take the system down.

Q: How is this different from existing commercial tools (e.g., Proofpoint, Abnormal Security, Microsoft Defender for Office 365)? A: Position honestly — most commercial BEC-detection tools *also* use ML/LLM reasoning, so your differentiator should be the **offline-first resilience design and being open/lightweight enough for smaller orgs that can't afford enterprise-tier licensing**, not "we invented semantic detection."

Q: What's the cost model? A: Heuristics are essentially free (local compute); LLM calls only fire on ambiguous cases, minimizing per-message cloud cost — quantify this if possible (e.g., "X% of messages resolved without an LLM call").

Q: How do you handle non-English phishing attempts? A: Address honestly — if untested, say so and put it on the roadmap; if tested, share results.

Q: What's your data retention and compliance posture (GDPR/DPDP Act)? A: PII is anonymized before cloud transmission; local logs can be configured with retention limits — tailor this to whatever you've actually implemented.

Q: Could an attacker adjust their message to evade the LLM's rubric? A: Acknowledge the adversarial nature of the problem honestly — layered heuristics (domain age, reputation) provide a check that's harder to evade purely through wording changes than the LLM layer alone.

Q: What's your future roadmap? A: e.g., broader language support, attachment/QR-code phishing analysis, browser extension, SOC dashboard integration, fine-tuned local model to reduce cloud dependency further.

10. Judging-Criteria Alignment (map explicitly if SIH gives a rubric)

- **Innovation:** hybrid fail-safe architecture, not just "LLM wrapper around an email filter."
- **Technical feasibility:** already-working layers (heuristics, RDAP, VirusTotal, LLM reasoning, offline fallback).
- **Real-world impact:** BEC/social engineering is the actual dominant attack vector today — ground this in your problem statement.
- **Scalability/cost-efficiency:** heuristics pre-filter, so LLM calls (the expensive part) only run when needed.
- **Resilience/reliability:** the offline fallback is a genuine engineering differentiator most hackathon projects skip entirely — emphasize it heavily.

11. Risks & Honest Weak Points (prepare answers, don't hide these)

- Dependence on third-party reputation APIs (RDAP, VirusTotal) for real-time data — rate limits/availability of those services is itself a dependency; be ready to discuss how you'd handle *their* outages too (your local heuristic + offline layer already covers most of this).
- Offline rubric classifier is inherently less accurate than the LLM layer — be transparent that it's a "keep the lights on" fallback, not a replacement.
- Needs a labeled dataset for credible accuracy claims — if you don't have one yet, say what you're using and what you'd add with more time.

12. Team Prep Checklist

- ☐ Have real (even small-scale) accuracy numbers ready
- ☐ Rehearse the "kill the network" live demo at least twice
- ☐ Assign one person to handle technical Q&A, one for business/impact Q&A
- ☐ Have a backup recorded demo video in case live demo/wifi fails at the venue (ironic, but do it)
- ☐ Prepare one slide with a clear cost/scale comparison vs. a named competitor if asked